PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sélection de pare-feux pour zones exposées

03-440 ANSSI - Recommandations pour choisir des pare-feux maîtrisés dans les zones exposées à Internet — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. L'architecture en cascade doit utiliser au moins deux pare-feux pour éviter un point de défaillance unique.
2. La virtualisation est déconseillée car l'isolation de l'hyperviseur est difficile à démontrer.
3. Pour la Diffusion Restreinte, il faut au moins un pare-feu qualifié standard en coupure des flux vers le réseau de classe zéro.

Principes de l'architecture en cascade

Notion	À retenir
Au moins deux pare-feux	Éviter un **point de défaillance unique** où la compromission expose l'ensemble des ressources du SI.
Diversification technologique	Préférer des technologies différentes (**matériel**, **OS**, **moteur de filtrage**, **IHM**) si les équipes les **maîtrisent**, sinon **rationaliser** l'historique.

Choix du type de pare-feu

Notion	À retenir
Dédicace fonctionnelle	Les pare-feux externe et interne doivent être **dédiés exclusivement au filtrage réseau** (sans VPN IPsec ni détection d'intrusion) pour réduire la **surface d'attaque** et les erreurs.
Préférence physique	La virtualisation est **déconseillée** (surtout pour systèmes **Diffusion Restreinte** ou **sensibles**) car l'isolation de l'hyperviseur est difficile à démontrer. Si utilisées, les instances doivent être sur des **socles physiquement séparés**.

Pare-feu physique vs virtualisé

	Pare-feu physique	Pare-feu virtualisé
Définition	Appliance prête à l'emploi ou **socle matériel durci**	Instance sur appliance physique virtualisée ou **appliance virtuelle** sur hyperviseur
Recommandation	Préféré	**Déconseillé** de façon générale
Isolation	Matérielle	Difficile à démontrer (ressources partagées de bas niveau)
Condition d'usage	N/A	Si utilisés, les instances doivent être sur des **socles physiquement séparés** (jamais mutualisées)

Qualification des pare-feux par niveau de sensibilité

Notion	À retenir
Recommandation générale	Mettre en œuvre des pare-feux **qualifiés** quel que soit le niveau de sensibilité. Si marché limité : second pare-feu **certifié critères communs** ou **CSPN** possible après analyse.
Diffusion Restreinte	Au moins un pare-feu **qualifié standard** en coupure des flux vers/depuis le **réseau de classe zéro**. Second pare-feu **technologiquement différent**.
Systèmes sensibles/non protégés	Systèmes **sensibles** : principes **Diffusion Restreinte** applicables. **Administrations de l'État** et entités **PST** : pare-feux **qualifiés ANSSI** obligatoires. Systèmes **non protégés** : qualification et diversification **recommandées**.

Hiérarchie et positionnement (Diffusion Restreinte)

- **Second pare-feu**, par ordre décroissant : **qualifié standard**, puis **élémentaire**, puis **simplement certifié**.
- **Un seul** pare-feu qualifié standard : de préférence en position **externe** (contact du réseau de moindre confiance).
- **Autre position** : à **justifier**, risque résiduel **formellement accepté** (ex: dossier d'homologation).

Architectures à plus de deux pare-feux

Notion	À retenir
Généralisation	Mêmes règles : **diversification**, **dédicace au filtrage**, produits **qualifiés** ou à défaut **certifiés** ; jamais au détriment de la **maîtrise** par les équipes.
Équipements en frontal	Le réseau de classe zéro n'est pas forcément Internet : un pare-feu **non qualifié** peut protéger en frontal le pare-feu qualifié (ex: **anti-DDoS**, absent des produits qualifiés).

Pièges et confusions

⚠ Croire que la cible de sécurité d'un produit qualifié est définie par l'éditeur lui-même.
⚠ Penser qu'un compte d'administrateur de l'hyperviseur permet de maintenir une séparation stricte entre administration système et réseau.
⚠ Confondre la certification technique et la qualification qui intègre une analyse organisationnelle de l'éditeur.
⚠ Supposer qu'un attaquant ne peut pas contourner la politique de sécurité d'un pare-feu virtualisé via l'hyperviseur.

Sigles et définitions

DMZ	Zone entre le pare-feu externe et le pare-feu interne
Pare-feu qualifié	Produit certifié dont l'éditeur a suivi avec succès le processus de qualification de l'ANSSI
Pare-feu certifié	Produit dont la robustesse a été évaluée par un CESTI indépendant
Réseau de classe zéro	Réseau public ou connecté à un réseau public non sécurisé par des dispositifs de filtrage qualifiés
Qualification élémentaire	Niveau de qualification à l'issue d'une CSPN
Qualification standard	Niveau de qualification à l'issue d'une certification critères communs EAL 3+
Qualification renforcée	Niveau de qualification à l'issue d'une certification EAL 4+

Auto-test

1. Quelle est la zone située entre le pare-feu externe et le pare-feu interne ?
2. Quelle technologie est préférée pour garantir une isolation matérielle ?
3. Que doit-on faire si l'on utilise des instances de pare-feux virtualisés ?
4. Quel niveau de qualification est requis pour la Diffusion Restreinte en coupure des flux ?
5. Quelle fonction est absente des produits qualifiés ?

Réponses : **1.** DMZ · **2.** Pare-feu physique · **3.** Les mettre sur des socles physiquement séparés · **4.** Qualifié standard · **5.** Fonction anti-DDoS

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.